Contents

Software Design Document — music-room **1**
1. Introduction . . . 1
2. References . . . 2
3. Stakeholders and design concerns . . . 2
4. Context viewpoint . . . 3
5. Composition viewpoint . . . 3
6. Logical viewpoint — domain model . . . 5
7. Dependency viewpoint . . . 6
8. Information viewpoint . . . 6
9. Interface viewpoint . . . 8
10. Interaction viewpoint . . . 10
11. State dynamics . . . 12
12. Concurrency viewpoint . . . 13
13. Security design . . . 14
14. Deployment and resource viewpoint . . . 19
15. Design rationale . . . 21
16. Requirements traceability . . . 22
17. Open design issues . . . 42
Related . . . 47

Software Design Document — music-room

Consolidated design view of the system, organised by the viewpoints of IEEE 1016.

Status: partly implemented. S0 through S2, S5, S6 and S7 are merged, and S3 is still open: identity, credential rate limits, the audit log, bearer authentication, own-profile editing, the Playlist Editor, Track Vote and Control Delegation with Playback all exist. The three services subject V.2 asks for are all built. Still absent: the catalog (S4), the mail adapter (S1a), the vault (S1b), the OpenAPI UI (S3a), OpenID Connect (S8) and the capacity evidence (S9). **§16 is the authority for what is built** — it says which rows that covers and which are still design only; `docs/progress/PROGRESS.json` carries the counted figures. Every section below describes what is decided, and marks what is not with `UNKNOWN - requires decision`. A guess is never substituted for a decision.

---

1. Introduction

1.1 Purpose

One document an evaluator, a new teammate, or a future maintainer can read to understand how the system is designed and why. It consolidates the design; it does not replace the layers that own each part.

1.2 Scope

The `music-room` backend and the contract it exposes to clients. The React Native client is out of the current work scope — only the constraints it places on the backend appear here ([[ADR-0002-mobile-react-native]]).

1.3 Audience

Peer evaluators, team members, and any agent working in this repository.

1.4 Authority order

When two sources disagree:

`42 subject -> ADR -> standard -> this document -> note -> code comment`

This document **consolidates**; it is not the source of truth for anything. Rationale lives in ADRs, enforceable rules live in `docs/technical-guide/`, requirements live in the subject.

1.5 Relationship to the other layers

Layer	Owns	This document does
`brain/constraints/`	what is required	quote and trace it
`brain/decisions/`	why a choice was made	reference it, never restate the rationale
`brain/architecture/`	the working design notes	consolidate them into one readable view
`docs/technical-guide/`	enforceable rules	reference, never copy
`docs/owasp/`	the security conformance target and its evidence	reference, never copy
`MusicRoom/`	what the code does	describe intent only

---

2. References

Ref	Source
R1	42 subject "Music Room", v6 — `docs/subject/en.subject tr.pdf`, distilled in [[subject-requirements]]
R2	[[decisions-index]] — ADR-0001 through ADR-0006
R3	[[technical-guide-index]] — 19 engineering standards
R4	IEEE 1016 — software design description, used here as the section structure
R5	RFC 9110 (HTTP semantics), RFC 9457 (Problem Details), RFC 9700 (OAuth 2.0 BCP), OpenID Connect Core 1.0
R6	OWASP ASVS 5.0.0, vendored at `docs/owasp/upstream/asvs-5.0.0/`; conformance scope in [[asvs-conformance]]
R7	NIST SP 800-63B — password and verifier requirements

---

3. Stakeholders and design concerns

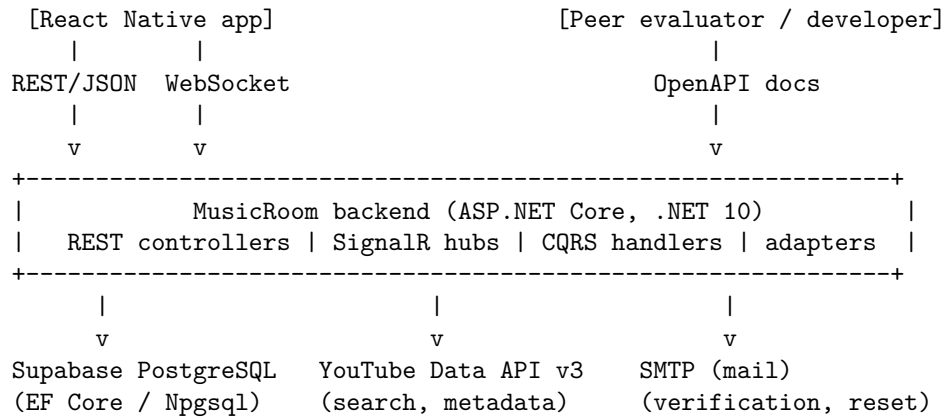
Stakeholder	Primary concern	Addressed in
End user at an event	the queue reflects the group's votes, immediately	§11, §12
Event owner	control over who may vote and edit	§9.2, §13.2
Peer evaluator	every mandatory requirement is met and defensible	§16

Stakeholder	Primary concern	Addressed in
Team developer	knowing where code goes and which rule applies	§5, §7
Operator	the system can be run, measured, and recovered	§14

---

4. Context viewpoint

4.1 System context



4.2 External actors and interfaces

External element	Direction	Protocol	Owned by
React Native client	inbound	HTTPS REST/JSON, WebSocket	us (deferred)
Supabase PostgreSQL	outbound	PostgreSQL wire protocol	vendor, managed
YouTube Data API v3	outbound	HTTPS REST	vendor
YouTube player SDK	client-side only	—	vendor
Google / Facebook OIDC	outbound	OAuth 2.0 + PKCE	vendor
Mail provider	outbound	HTTPS API	hosted free tier – [[ADR-0013-mail-provider]]

Design constraint. No client ever reaches Supabase or YouTube Data API directly. Subject R1 V.3 makes the backend the single guardian of truth, and V.6 makes it the single authorisation gate. A direct client connection would route around both. See [[ADR-0006-datastore]].

---

5. Composition viewpoint

5.1 Physical composition

One repository, two application roots – [[ADR-0020-monorepo-layout]]:

Root	Contents	Owner
`MusicRoom/`	backend, .NET 10	backend developer
`MusicRoomApp/`	React Native client	UI developer

One clone is the whole submission, which subject VII requires. Neither root writes into the other; the contract between them is [[endpoint-inventory]] and the generated `docs/api/openapi.json`. `reference/` is read-only study material, never built, referenced or copied from – see [[reference-narchitecture]].

Five projects, per [[clean-architecture-cqrs]]:

Project	Responsibility
`Domain`	entities, value objects, enums, domain rules, domain exceptions
`Application`	commands, queries, handlers, validators, pipeline behaviours, abstractions
`Persistence`	`DbContext`, entity configurations, repositories, EF Core migrations
`Infrastructure`	YouTube adapter, mail, token and OTP services
`WebAPI`	controllers, SignalR hubs, middleware, DI composition, OpenAPI

Layout mirrors the reference repository – [[ADR-0011-solution-layout]]:

```
MusicRoom/
  MusicRoom.sln
  src/
    corePackages/   Core.Application | Core.CrossCuttingConcerns | Core.Persistence | Core.Security
    MusicRoom/      Domain | Application | Persistence | Infrastructure | WebAPI
  tests/
    <Project>.Tests/
```

The shape is copied; no file is. A type enters `corePackages` only if it is domain-agnostic.

5.2 Logical composition — bounded contexts

Context	Owns	Subject ref
Identity	user, credentials, email verification, password reset, social links	V.1
Profile	profile fields with per-field visibility, music preferences	V.1
Event (Track Vote)	event, attendee, track suggestion, vote, licence policy	V.2.1
Playlist (Editor)	playlist, collaborator, ordered tracks	V.2.3
Delegation (Control)	device, control grant	V.2.2
Playback	playback session, now-playing pointer, queue advance	V.2.1, V.2.2
Catalog	YouTube track lookup and cache	V.2, III
Audit	per-action record: platform, device, app version	V.6

Subject R1 V.2 requires at least 2 of 3 services. **All three ship** – [[ADR-0010-service-scope]]. Identity, Profile, Catalog and Audit are required regardless.

Consequence: the location+time licence mode is mandatory, decided in [[ADR-0014-location-time-licence]]. If the schedule slips, Control Delegation is dropped first – it is the smallest, and removing it still leaves two services, satisfying V.2.

---

6. Logical viewpoint — domain model

Detail source: [[domain-model]]. Field-level detail is deliberately absent until the first migration exists.

6.1 Aggregates

Aggregate	Root	Key invariant
User	`User`	email unique; an unverified email cannot use services
Profile	`Profile`	every field carries one of `Public / Friends / Private`
Event	`Event`	one vote per user per track; ranking derives from vote count
Playlist	`Playlist`	position ordering stays total and gap-tolerant
Device	`Device`	a control grant belongs to exactly one device
PlaybackSession	`PlaybackSession`	at most one active session per device; `controllerUserId` is what a control grant changes
TrackRef	value object	a YouTube reference only — never media content

6.2 Shared enumerations

Enum	Values	Source
`Visibility`	`Public`, `Private`	R1 V.2.1, V.2.3
`LicenceMode`	`Everyone`, `InvitedOnly`, `LocationAndTimeRestricted`	R1 V.2.1, V.2.3
`PresenceProof`	`Geofence`, `EventCode`, `Both`	policy carried by `LocationAndTimeRestricted` – [[ADR-0014-location-time-licence]]
`ProfileFieldVisibility`	`Public`, `Friends`, `Private`	R1 V.1 — **implemented**, stored as `smallint` per field ([[ADR-0034-profile-storage-and-visibility]])
`FriendRequestStatus`	`Pending`, `Accepted`, `Declined`	R1 V.1 — **implemented**. There is no `Cancelled`: a withdrawn request is deleted
`MusicPreferenceKind`	`Genre`, `Artist`	R1 V.1 — **implemented**
`Platform`	`iOS`, `Android`, `Web`, `Other`	R1 V.6

The reader's relationship to a profile — self, friend or stranger — is **derived per request** from the token and the friends graph, never stored, so it is not an enumeration this table owns.

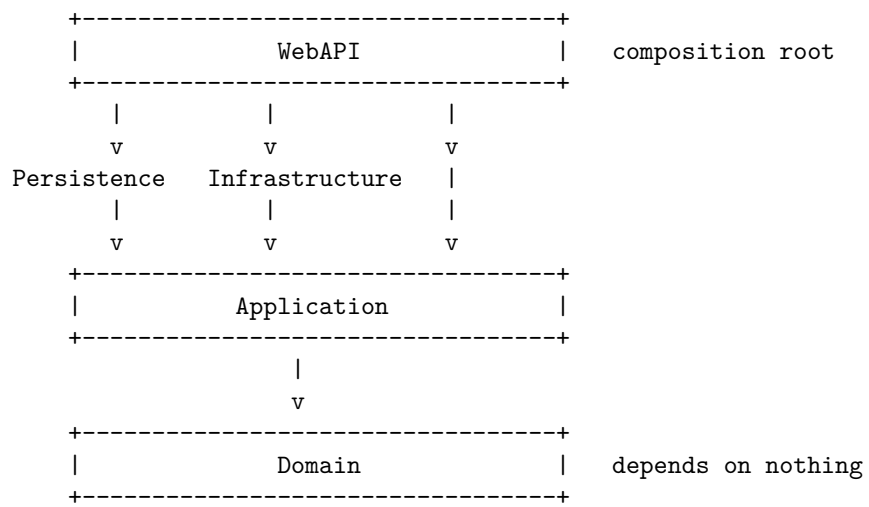
6.3 Deliberate exclusions

Audio and video content is never stored, cached, proxied or re-hosted. Only `TrackRef` metadata is persisted — [[ADR-0003-music-provider-youtube]].

---

7. Dependency viewpoint

7.1 The dependency rule



Enforced constraints, from [[clean-architecture-cqrs]]:

- `Domain` references no other project and no infrastructure package.
- `Application` references neither EF Core, nor ASP.NET Core, nor any vendor SDK.
- `WebAPI` never touches `DbContext` directly.
- A reference pointing outward is a build-breaking defect, not a style issue.

7.2 External dependency boundaries

External system	Isolated behind	Located in
YouTube Data API	one adapter, interface declared in `Application`	`Infrastructure`
SMTP	mail service abstraction	`Infrastructure`
Google / Facebook	provider token validation service	`Infrastructure`
PostgreSQL	repositories + `DbContext`	`Persistence`

---

8. Information viewpoint

8.1 Storage

Supabase-managed PostgreSQL, accessed through EF Core with the Npgsql provider ([[ADR-0006-datastore]]). Only the Postgres surface is used — Supabase Auth, Realtime, Storage and PostgREST are deliberately not adopted, because identity, realtime and the API are ours.

8.2 Constraints that carry invariants

Conventions and full rules: [[database-design-migrations]].

Constraint	Protects	Why it is in the database
`ux_votes_event_id_track_id_user_id`	one vote per user per track	a read-then-write check in C# is a race condition
`ux_users_email`	account uniqueness	concurrent registration
`xmin` concurrency token on `playlists`	reorder conflicts	last-writer-wins must be detectable
`xmin` concurrency token on `devices`	control takeover	two simultaneous claims must not both succeed

8.3 Common columns

Every table: `id`, `created_at_utc`, `updated_at_utc`. User-owned aggregates use soft delete (`deleted_at_utc`) so the audit trail survives. All instants are `timestamp with time zone`, written as UTC.

8.4 Ordering strategy

Playlist position uses sparse ordering keys with gaps, so inserting between two tracks does not rewrite the list. See §12.2.

8.5 Schema ownership and evolution

- EF Core migrations are the only mechanism that changes the schema. Editing the schema in the Supabase dashboard desynchronises migration history and is treated as an incident.
- Two connection strings: pooled (Supavisor) for the API, **direct** for migrations.
- Destructive changes follow expand -> migrate -> contract.
- Every migration is recorded in [[migrations-index]].
- **The schema tool does not start the application.** `MusicRoomDesignTimeDbContextFactory` builds the context for `dotnet ef` from `DATABASE_URL` alone, so `make migrate` and `make migration` depend on the one setting they use and on nothing else (SPEC-029). Before it, `dotnet ef` fell back to the web host and ran every start-up guard the host has: a `.env` with `MAIL_PROVIDER=brevo` and an empty `MAIL_FROM` stopped a migration. The guards stay as they are — they close threat T-26 — and the factory takes the schema off their path. A missing `DATABASE_URL` is still a refusal naming the key, because ADR-0026 gives it no default on either path.

`playlists` holds one row per playlist with `owner_id`, `visibility`, `licence` and `deleted_at_utc`, and uses PostgreSQL's `xmin` as its concurrency token — no version column exists, which is what makes the `ETag` of §5 free (SPEC-014). Deletion is soft, applied by a global query filter. `playlist_collaborators` holds one row per person named on a playlist with `can_edit`, unique per playlist and account. `playlist_tracks` holds one row per track with a `bigint position`, a sparse key with a nominal gap of 1000 so an insert between two tracks writes one row; the index on `(playlist_id, position)` is **not unique**, because a renumber rewrites a whole playlist in one batch and nothing needs the uniqueness — every track write first updates the playlist row, which is also what gives the track **list** the `ETag` a collection cannot carry itself (SPEC-015).

`playback_sessions` holds one row per session with its device, a `(source_type, source_id)` pair naming an event or a playlist, the now-playing id, and `ended_at_utc`. `ux_playback_sessions_device_id` is **filtered** on `ended_at_utc IS NULL`, which is how ADR-0017's "at most one active session per device" becomes a constraint the database keeps; history accumulates behind it. There is **no controller column** — who may command a session is read from its device — and **no foreign key on `source_id`**, because one column pair for two possible parents is the honest shape (SPEC-021).

`devices` holds one row per registered device with its owner, the three client values it reported, and `controller_user_id` — the control grant itself, nullable because null means the owner controls it. The

row's `xmin` is the concurrency token that makes two simultaneous claims resolve to one `200` and one `412`. `ux_devices_owner_id_platform_model` excludes the app version on purpose: a phone that updates its app is the same phone (SPEC-020).

`event_suggestions` holds one row per track suggested for an event, unique per event and video. `event_votes` holds one row per account per suggestion, unique on `(event_id, suggestion_id, user_id)` — **and there is no count column anywhere**: the queue counts these rows on every read, so no two writers can disagree about a ranking and no increment can be lost (SPEC-018). `event_codes` holds a SHA-256 digest and an expiry, not a plaintext code, and `event_code_redemptions` is unique per code and account, which is what makes "single use per account" a fact the database holds. A voter's submitted coordinates are compared against the event's centre and discarded — they reach no row and no log ([[ADR-0014-location-time-licence]]).

`events` holds one row per track-vote event with `owner_id`, `visibility`, `licence`, a UTC window, and four nullable policy columns carrying [[ADR-0014-location-time-licence]]'s configuration — `presence_proof` and a `numeric(9,6)` centre with a radius in metres. It uses `xmin` as its concurrency token and `deleted_at_utc` for soft delete, the same mechanisms the playlist aggregate uses. The coordinates are the **venue's**; a voter's are checked and discarded and never stored. `event_invitations` is the `member` gate on a private event, unique per event and account; `event_attendances` is a roster and is read by nothing that decides whether somebody may act (SPEC-017).

`friend_requests` holds one row per ordered pair, unique on `(sender_id, recipient_id)`, with a `smallint` status — pending, accepted or declined. `friendships` holds **one row per friendship** with the pair in canonical order, `user_a_id < user_b_id`, unique on the pair: symmetry is a property of the data rather than of two rows that could disagree, and the unique index is what makes the friendship two crossing accepts would create impossible (SPEC-012).

`profiles` holds one row per account with a value column and a `smallint` visibility column per tiered field — `real_name`, `bio`, `location`, `birth_date` — created with the account so no read path has to answer for a missing profile. `music_preferences` holds one row per named genre or artist, unique per account, kind and value. `display_name` stays on `users`: it is always public (SPEC-011).

Concrete table and column definitions live in the migrations and their `IEntityTypeConfiguration` files, which are authoritative — [[migrations-index]] is the list, and this section does not repeat it. For a table no migration has created yet it is still `UNKNOWN - requires decision`.

---

9. Interface viewpoint

9.1 REST API

Rules: [[rest-api-design]]. Documentation: [[openapi-documentation]].

Aspect	Design
Base path	`/api/v1`
Format	JSON, `camelCase`, UTF-8
Errors	RFC 9457 `application/problem+json`, one shape, with `traceId`
Collections	envelope `{ items, page, pageSize, total }`, page size capped
Timestamps	UTC ISO-8601
Privacy rule	a resource hidden from the caller returns `404`, never `403`
Auth	bearer JWT
Mandatory headers	`X-Client-Platform`, `X-Client-Device`, `X-Client-App-Version` on mutations

Aspect	Design
Documentation	OpenAPI 3.1 generated from code, exported to `docs/api/openapi.json`. The document is served at `/openapi/v1.json` in every environment
Documentation UI	**Swagger UI, Development only** – `Swashbuckle.AspNetCore.SwaggerUI` renders the document above; the generator stays `AddOpenApi()` so one producer describes the API. Slice S3a – [[ADR-0035-swagger-ui-for-the-openapi-document]]

The endpoint inventory is [[endpoint-inventory]] – around 60 endpoints across Identity, Profile, Catalog, Track Vote, Playlist Editor, Control Delegation, audit and operations, plus the client-to-server hub methods. Concrete request and response schemas come from the generated OpenAPI document, not from that file.

9.2 Realtime API

Rules: [[signalr-realtime]]. Rationale: [[ADR-0004-realtime-signalr]].

Hub	Group key	Server-to-client events
`EventHub`	`event:{eventId}`	`TrackSuggested`, `VoteChanged`, `QueueReordered`, `NowPlayingChanged`
`PlaylistHub`	`playlist:{playlistId}`	`TrackAdded`, `TrackRemoved`, `TrackMoved`, `CollaboratorChanged`
`ControlHub`	`user:{userId}`	`ControlGranted`, `ControlRevoked`, `ControlTakenOver`

Contract rules:

All three hubs are **implemented**: `PlaylistHub` at `/hubs/playlists` (SPEC-016), `EventHub` at `/hubs/events` (SPEC-019) and `ControlHub` at `/hubs/control` (SPEC-022), behind one broadcast queue, one pipeline behaviour and one audit filter. `ControlHub` alone has no invocable method — its group is a person, joined from the validated token on connect, so there is nothing for a client to ask for and nothing to audit (ADR-0019 audits hub methods).

- Hubs are transport only. Every hub method dispatches the **same** CQRS handler the REST endpoint uses, so the two transports cannot diverge.
- Every payload carries the aggregate id. A playlist payload also carries a monotonic `version`, which is the parent row's `xmin` and the token its `ETag` carries. An **event** payload carries the authoritative value of what changed instead – a written, scoped deviation recorded in [[ADR-0039-queue-broadcast-payloads]]: an event's `xmin` is already the `If-Match` of its metadata `PATCH`, and a `queue_version` column would reintroduce the shared mutable count §12.2 forbids. Either way a client converges, which is what the rule is for.
- Group membership is authorised server-side on every join and re-checked on reconnect.
- A broadcast is emitted only after the transaction commits. The mechanism is structural rather than remembered: a handler queues what happened, and a pipeline behaviour registered **outside** the one that owns the transaction drains that queue once it has committed – [[ADR-0038-realtime-broadcast-posture]].
- Client context is captured at the handshake from the query string, and a handshake without it is answered `400` by the same middleware that refuses a REST mutation without the headers – [[ADR-0019-hub-action-auditing]].

9.3 External interfaces

Interface	Usage	Design note
YouTube Data API v3	`videos.list` preferred; `search.list` only on real user input	**built, SPEC-025.** Quota is billed in units and `search.list` costs about a hundred times a `videos.list`, so one adapter reaches the provider and two cache levels stand in front of it: `IMemoryCache`, then `track_refs`, then YouTube — [[ADR-0023-catalog-cache]]. A searched query's id list is cached as well, in `track_search_cache`, so a repeated search re-issues nothing. Every call logs its unit cost, `403 quotaExceeded` and a provider `5xx` both answer `503`, and the pipeline carries a per-attempt timeout, a bounded retry on `5xx` and `429` only, and a circuit breaker. With no key configured the caches still answer
YouTube player SDK	client-side playback	backend decides what and when, never streams media
Google / Facebook	authorization code flow with PKCE	provider token validated server-side against JWKS; a client-supplied profile is never trusted
Mail provider	verification and reset mail	hosted free tier behind `IMailService`; API key server-side – [[ADR-0013-mail-provider]]

The catalog degrades rather than failing. `youtube-integration` requires an event to keep running when the provider does not: a stale `track_refs` row is served in preference to an error, and a write path — suggesting a track, adding one to a playlist — never calls the provider at all. It validates the video id's shape and stores it, and metadata is resolved on read. So a spent quota costs titles, not votes.

---

10. Interaction viewpoint

Representative flows. Steps are design intent, not implemented code.

10.1 Registration with email and password

```
1. Client POST /api/v1/auth/registrations
2. Validation behaviour rejects malformed input, including the 12-64 character
   and 72-byte UTF-8 password limits that BCrypt requires
3. Handler hashes the password with BCrypt at cost >= 12, persists an unverified User
4. Infrastructure sends a verification mail with a single-use, hashed, 24h token
5. Response 202, always -- identical whether or not the address is already registered.
   A 409 here would be an account-enumeration oracle; the mailbox tells the real story.
```

```
   The account cannot use services until verified
6. Client POST /api/v1/auth/email-verifications with the token
7. Handler marks the account verified and consumes the token
```

Algorithm: [[ADR-0007-password-hashing-bcrypt]]. Paths and status codes: [[endpoint-inventory]] §1.

Step 4 sends real mail since SPEC-024. `MAIL_PROVIDER` chooses the sender: `brevo` is the hosted provider of [[ADR-0013-mail-provider]], and `logging` is the Development-only sender that writes the link to the application log. Neither is a default — a host with no valid value does not start, which is what replaced the "Development only" guard and what closes issue O17 and threat T-26. The message carries the token and nothing else personal, as HTML and plain text, composed in this repository rather than in a vendor template.

The provider path is **verified end to end**, once, by hand on 2026-10-04: a registration answered `202`, Brevo accepted the message with `201`, and it arrived in a real mailbox. No automated test spends quota (SPEC-024 decision 7), so that run is the only evidence the call itself works, and it is recorded in SPEC-024's verification table rather than claimed by a test. `MAIL_API_KEY` is a **v3 API key**, not an SMTP key: the adapter calls `POST /v3/smtp/email`, which answers `401` to an SMTP key.

The sender is **Brevo's sandbox sender**, not a verified domain: ADR-0013 permits that for the defence provided it is stated rather than presented as production, and this is the statement. `VERIFICATION_LINK_BASE_URL` and `PASSWORD_RESET_LINK_BASE_URL` decide where the links point; with neither set the message carries the bare token, because a link to a machine nobody intended is worse than no link. One send, bounded at 10 seconds, with no retry: the resend endpoint is the retry path and it is rate-limited, and a failed send never rolls the registration back — that is what keeps the `202` above from becoming an enumeration oracle.

10.2 Social login

OpenID Connect, not bare OAuth 2.0 – [[ADR-0008-oidc-social-login]].

```
1. Device runs the OIDC authorization code flow with PKCE
2. Client POST /api/v1/auth/social with the provider ID TOKEN (never an access token)
3. Server validates, in order:
     a. signature against the provider JWKS from its discovery document
     b. iss matches the expected issuer
     c. aud matches our client id      <- stops token substitution
     d. exp and iat within tolerance
     e. nonce matches the one this server generated
     f. email_verified is true before any email-based account match
4. Server maps (provider, providerUserId) to a local user, or creates one
5. Server issues ITS OWN access + refresh token pair
   - a provider token is never accepted as an API credential
```

Provider asymmetry: Google is a full OIDC provider; Facebook is not uniformly OIDC (Limited Login issues an ID token, classic Facebook Login does not). The integration branches. See [[social-oauth]].

10.3 Casting a vote — the contended write path

```
1. Client POST /api/v1/events/{eventId}/tracks/{trackId}/votes
2. Authorisation behaviour evaluates ownership, then Visibility and LicenceMode
3. Rate limiting behaviour applies per account and per IP
4. Transaction behaviour opens the transaction
5. Handler inserts the vote row
   - the unique index is the arbiter; a duplicate insert fails here, not in C#
   - a duplicate is mapped to 409 Conflict, never silently ignored
6. Vote count is recomputed from the source rows, never incremented in memory
7. Transaction commits
```

```
8. ONLY THEN: EventHub broadcasts VoteChanged and QueueReordered to event:{eventId}
```

Step 8 after step 7 is the rule that prevents clients from seeing state the server rolls back.

10.4 Moving a track in a playlist

```
1. Client PATCH .../playlists/{id}/tracks/{trackId} with the target position,
   carrying the playlist's current concurrency token
2. Authorisation behaviour evaluates Visibility and LicenceMode for edit rights
3. Handler computes a new sparse ordering key between the neighbours
4. Save fails with DbUpdateConcurrencyException if another edit landed first
   - the handler reloads and reapplies, or returns 409
5. On commit, PlaylistHub broadcasts TrackMoved with the new version
6. Clients treat the event as a reconcile hint, tolerating duplicates and reordering
```

10.5 Delegating music control

```
1. Owner POST .../devices/{deviceId}/control-grants with the target friend
2. Handler transitions the Device control state under its concurrency token
3. A competing claim loses on the concurrency token - it must not silently win
4. ControlHub notifies user:{ownerId} and user:{granteeId}
```

10.6 Advancing the queue

```
1. Controller device detects the current track ended
2. POST /api/v1/playback-sessions/{id}/advances  { expectedNowPlayingId }
3. Authorisation behaviour verifies the caller is the session's controllerUserId
4. Handler picks the next item:
     Event    -> highest vote count, ties broken by earliest suggestion
     Playlist -> next ordering key
5. Write under the concurrency token; a stale expectedNowPlayingId returns the current
   state instead of skipping a second track
6. Commit
7. ONLY THEN: NowPlayingChanged broadcast to the source's group
```

The server is the arbiter of **what** plays; the client is the authority on **when** it ended. The backend cannot observe audio, and a `durationSeconds` timer drifts on pause and buffering. See [[ADR-0017-playback-session]].

10.7 Every mutating request — the mandatory audit path

```
1. Middleware reads X-Client-Platform, X-Client-Device, X-Client-App-Version
2. Missing headers on a mutating request -> 400 (a silent default would void R1 V.6)
3. Values are attached to the request scope
4. An audit behaviour writes one audit record per handled command
```

---

11. State dynamics

11.1 Account state

```
Registered(unverified) --verify--> Active
Active --reset password--> Active (all refresh tokens revoked)
```

An unverified account cannot use the three services.

11.2 Playback session state

```
None --create--> Playing(nowPlaying)
Playing --advance--> Playing(next)      server picks next; idempotent on expectedNowPlayingId
Playing --advance--> Ended              queue exhausted
Playing --delete--> None
```

If the controller device goes silent mid-track, nothing advances. Accepted: control can be taken over via `PUT /devices/{id}/control` and the owner can always revoke. No server-side watchdog – it would reintroduce the drift this design avoids.

11.3 Device control state

Single-row state machine on `Device`, guarded by a concurrency token:

```
Uncontrolled --claim--> ControlledBy(owner)
ControlledBy(owner) --delegate--> ControlledBy(grantee)
ControlledBy(x) --revoke--> ControlledBy(owner)
ControlledBy(x) --release--> Uncontrolled
```

Concurrent transitions are resolved by the token. Exact state names are settled when the Delegation slice is built.

---

12. Concurrency viewpoint

Subject R1 V.2.1 and V.2.3 both call out race conditions explicitly. They are graded, so they are designed here rather than discovered in review. Full notes: [[realtime-architecture]].

12.1 Hotspots

#	Hotspot	Failure if unhandled
1	two users vote on the same track simultaneously	duplicate votes, wrong ranking
2	two users reorder the same playlist simultaneously	divergent order, lost move
3	two devices claim control at once	two controllers, undefined playback
4	two clients advance the same playback session at once	a track is silently skipped

12.2 Mechanisms

Hotspot	Mechanism
1	unique index `(EventId, TrackId, UserId)`; duplicate detected by the database, mapped to `409`
1	vote counts recomputed inside the transaction or aggregated database-side — never read-modify-write
2	sparse ordering keys plus an `xmin` concurrency token, **taken from the playlist row and updated inside the same transaction as the track write**, so the guarded `UPDATE` is both the `If-Match` check and the lock that serialises reorders; the losing writer gets `412` and reloads (SPEC-015)

Hotspot	Mechanism
3	single-row state machine with a concurrency token; the losing writer must lose visibly
4	`expectedNowPlayingId` in the request plus the session's concurrency token; a stale expectation returns current state rather than advancing again. **Implemented and proven** (SPEC-021): twenty parallel advances with one token move the session once, and an exhausted queue ends it once

12.3 Governing principles

1. **The database is the arbiter, not the hub and not the application.**
2. **Broadcast after commit.** Never inside the transaction.
3. **Every realtime event is a reconcile hint.** Clients must tolerate duplicates and reordering.
4. **A sequential test proves nothing about a race.** Concurrency cases run in parallel and assert final database state — [[testing]].

---

13. Security design

Full rules: [[authentication-authorization]], [[application-security]], [[secrets-management]]. Design notes: [[auth-and-identity]]. Conformance target: [[asvs-conformance]] — ASVS 5.0.0 Level 1 for every applicable chapter, Level 2 for V6 Authentication, V7 Session Management, V8 Authorization, V9 Self-contained Tokens, V10 OAuth and OIDC, and V16 Security Logging and Error Handling.

13.1 Authentication

Element	Design
Password hashing	**BCrypt** (`BCrypt.Net-Next`), work factor >= 12, rehash on login when the stored cost is lower – [[ADR-0007-password-hashing-bcrypt]]
Password policy	12 to 64 characters, **<= 72 bytes UTF-8** (BCrypt truncates beyond that), no composition rules, no forced rotation (NIST SP 800-63B)
Session	15-minute **RS256** JWT access token carrying `sub`, `sid`, `iat`, `exp` and `jti` — `sid` names the refresh-token family, which is what lets logout end one session and leave the others (SPEC-010) — plus an opaque, hashed, rotating refresh token. Validation allows **30 seconds** of clock skew, so a token is accepted for at most 15 minutes 30 seconds. The refresh family's lifetime is **30 days, absolute** — every rotation inherits the family's original expiry, so a stolen family cannot be kept alive by rotating it (owner decision, 2026-09-27, SPEC-005). From S8 an **ID token** joins the access token and both are issued by the API's own OpenID Provider surface – [[ADR-0031-musicroom-as-openid-provider]]
Theft detection	reuse of a rotated refresh token revokes the whole family

Element	Design
Verification / reset	single-use, hashed, short-TTL tokens; identical responses whether or not the account exists. **Delivery since SPEC-024:** the plaintext token leaves the process only inside the message the sender composes — the row keeps its SHA-256 digest, the provider's API key lives in the typed client, and neither the token nor the key reaches a log event on the hosted path. The Development sender still logs both, which is why it may run nowhere else (T-26, §10.1)
Password change	`POST /api/v1/me/password`, SPEC-028: the current password is the proof ASVS V7.5.1 asks for before a sensitive attribute changes, the new hash and the revocation of every **other** refresh family are one transaction, and the caller's own session survives because it just proved it holds the new credential. A wrong current password is `422`, not `401` — the token is valid, the precondition is not
Social	**OpenID Connect**; one validation core driven by each provider's discovery document, acquisition branching only: Google authorization code + PKCE `S256`, Facebook Limited Login. The ID token is validated server-side including `aud` and `nonce`; one provider identity maps to at most one user – [[ADR-0008-oidc-social-login]]
Provider role	from S8 the API is itself an **OpenID Provider**: discovery document, JWKS, authorization endpoint with PKCE `S256`, token endpoint, ID token, UserInfo. No resource-owner password-credentials grant – [[ADR-0031-musicroom-as-openid-provider]]

13.2 Authorisation — two independent gates

Both are mandatory and both server-side:

1. **Ownership** — the caller owns the resource or is an authorised participant (R1 V.6).
2. **Visibility and licence** — resolved from `Visibility` and `LicenceMode`, evaluated on every request and every hub join.

Where each gate lives today, which differs from the "one pipeline behaviour" this section originally assumed:

Gate	Mechanism	State
Ownership, own resources	the account comes from the validated token and no route accepts a caller id, so there is nothing to compare — `/me` routes, the session endpoints and the friends graph all work this way	**implemented**

Gate	Mechanism	State
Ownership, somebody else's resource	a resource that is not the caller's answers `404` from the statement that failed to match it, not from a prior check — one `UPDATE` or `DELETE` keyed on the caller	**implemented** for sessions, friend requests and friendships
Per-field visibility	resolved once per read into self / friend / stranger, then applied **inside the SQL projection**: a field the reader may not see is never read, so it cannot leak through a serialiser or a log (OWASP API3) — SPEC-013	**implemented**
Licence, including location and time	[[ADR-0014-location-time-licence]]	designed; arrives with the Track Vote slice
Hub join	the same two gates on every join	designed; arrives with the first hub

A pipeline behaviour is still the right home for the *licence* gate, because it will apply to many commands uniformly. It was the wrong home for per-field visibility, which is a projection rather than a yes-or-no answer.

Row Level Security as deny-by-default defence in depth is **designed and not implemented**: no migration creates a policy. Recorded as issue O19 in §17 — it is defence in depth, so its absence weakens nothing that the gates above already decide, and claiming it while it does not exist would be worse than owing it.

13.3 Abuse resistance

Rate limits keyed on account **and** IP for login, registration, reset, verification resend and vote casting. Progressive backoff on repeated login failure. Generic error text to prevent account enumeration. `429` with `Retry-After`.

The numbers, approved by the repository owner on 2026-09-27 (SPEC-006). Implemented values, not intent: the per-IP half is the built-in middleware, one policy per endpoint; the per-account half is `ICredentialAttemptLimiter`, enforced inside the handler because the address a request names is known only after model binding. Both halves hold state **in process**, which is correct for the single instance [[ADR-0015-hosting-and-deployment]] deploys and would not be shared across several – O8.

Endpoint	Per IP	Per named account
`POST /auth/sessions`	20 / 5 min	5 failures / 5 min, then a penalty of 1 window doubling to a ceiling of 8
`POST /auth/tokens`	60 / 5 min	– the request names no account, only a token
`POST /auth/registrations`	10 / hour	the same per-account counter, charged on **every** attempt
`POST /auth/verification-requests`	10 / hour	the same, charged on every attempt – each one writes a row and spends mail quota (T-19)
`POST /auth/email-verifications`	30 / 5 min	– the request names no account
`POST /auth/password-reset-requests`	10 / hour	the same per-account counter, charged on **every** attempt – SPEC-007

Endpoint	Per IP	Per named account
`POST /auth/password-resets`	30 / 5 min	– the request names no account, only a token
`POST /me/password`	10 / 5 min	the per-account counter, charged on a **wrong** current password and cleared by a correct one — SPEC-028

The realtime surface carries its own three controls since SPEC-026, which implemented the numbers [[ADR-0030-hub-rate-limits-and-origin]] left open until 2026-10-04:

Control	Value	Enforced
Concurrent connections per account	5	refused at the handshake (`429` + `Retry-After`) and again at connect
Concurrent connections per address	20	the same, which is the venue case — one network, many people
Hub invocations per connection	60 a minute	`HubException`, inside the audit filter, recorded `refused`
Handshake `Origin`	`CORS_ALLOWED_ORIGINS`	`403`; **no** `Origin` passes, which is the native client

Twice for the ceiling, because the two checks answer different problems: a refusal thrown in `OnConnectedAsync` does not reliably reach a client over long polling, and a middleware check reads a count it does not own, so two simultaneous handshakes can both pass it. The middleware gives the client a refusal it can see; the filter holds the authoritative count. Counts are **per process**, as every other limiter here is — O8.

`CORS_ALLOWED_ORIGINS` now governs REST as well. It had been in `.env.example` since S0 and read by nothing, so the handshake check the ADR specifies had no list to compare against; one list rather than two, because the ADR rejected a second allowlist on the grounds that two drift.

Login charges only a *failed* attempt and clears the counter on success. Registration and resend charge every attempt, because the cost is in the attempt rather than in its outcome. The defaults are compiled in and overridable from configuration; a non-positive override is ignored, so configuration cannot switch a limit off.

The vote and venue-code routes carry their own policies, keyed on the **validated account** rather than the address: 60 votes a minute and 10 codes in 5 minutes (SPEC-018). An event is a room full of people on one network, so an address key would make them share one allowance — which is exactly what happened until SPEC-023's load measurement found it. The limiter middleware ran before authentication, so the partition key saw no claims and silently took its address fallback. [[ADR-0041-limiter-after-authentication]] fixed the order: authentication, then the limiter, then authorisation, then the client-context middleware. The limiter still runs before any handler and any database work, so a flood is still refused cheaply — the load report measures a refusal at about one millisecond. `EventVoteRateLimitingTests` is the regression: two accounts on one address, and the second must still be able to vote.

13.4 Audit log — mandatory, and distinct from application logging

	Audit log	Application log
Purpose	satisfy R1 V.6 — record what a user did	diagnose the system
Store	database table, queryable	structured log sink
Retention	kept; it is evidence	rotated

	Audit log	Application log

Audit record: `userId`, `action`, `targetType`, `targetId`, `platform`, `device`, `appVersion`, `occurredAtUtc`, `correlationId`, outcome. See §10.7.

The log inventory — what is written where, which ASVS V16.1.1 asks for and SPEC-027 wrote down:

Layer	Sink	What it carries	What it must never carry
Audit	`audit_records` in PostgreSQL	one row per user action: the ten fields above, including the outcome vocabulary below	a password, a token, a token digest, or a geofence coordinate
Application	container **stdout**, Serilog CLEF (`CompactJsonFormatter`), `@t` in UTC	request lines from `UseSerilogRequestLogging`; start-up decisions; limiter trips with the policy and the wait; unhandled exceptions with their stack; the mail sender's recipient and provider message id; the catalog's call name and its quota cost in units	anything on the never-logged list in [[application-security]] — credentials, tokens, API keys, provider response bodies, and the account behind a rate-limit trip
Traces	OTLP exporter, **off by default** — [[ADR-0022-observability-stack]], issue O16	spans for the request, EF Core and outbound HTTP	the same list
Database	PostgreSQL's own log inside the container	engine errors, such as the `53300` connection exhaustion SPEC-023's run surfaced	not ours to control; it is why `Include Error Detail` stays off, so a constraint violation names no value

Two of the chapter's requirements are **not met** and are recorded as T-33: nothing restricts who may read these logs or makes them immutable (V16.4.2), and nothing ships them to a separate system for alerting (V16.4.3). The exporter above is the mechanism that would, and it is switched off.

The `outcome` vocabulary, implemented values (SPEC-009):

Value	Means
`completed`	the action ran to completion. Also what a handler that says nothing produces
`refused`	wrong credential, or an unknown or already-spent token
`throttled`	the account is out of attempts — §13.3
`expired`	the credential existed and its window had passed
`reusedetected`	an already-rotated refresh token was presented, so the family was revoked — §13.1. The loudest row in the table: a refresh token leaked

`userId` is set where the handler knows the account — a successful sign-in, a rotation, a completed reset — and left null where naming it would say more than the caller proved: a failed login must not record which address exists, and a duplicate registration stays `completed` for the same reason.

Both transports are covered. REST commands go through the pipeline behaviour; SignalR `JoinEvent`, `LeaveEvent`, `JoinPlaylist` and `LeavePlaylist` go through a hub filter writing the same record – [[ADR-0019-hub-action-auditing]]. Client context is captured at the handshake, since a hub invocation carries no HTTP headers, and a handshake without it is rejected. Connect and disconnect are deliberately not audited: mobile reconnect noise would bury deliberate user actions.

13.5 Never logged, never stored, never shipped to a client

Passwords, tokens, refresh tokens, API keys, `Authorization` headers, database connection strings, Supabase keys, OAuth client secrets. A mobile bundle can be unpacked, so it holds none of these.

13.6 Residual risk

R1 V.6 requires the remaining threats to be identified and their protections described. The register is [[threat-register]]: 18 threats with likelihood, impact, planned mitigation, residual risk, accepted-by and verification, plus an explicit out-of-scope list.

Every unfixed finding from [[owasp-top10-checklist]] or [[owasp-api-top10-checklist]] gets a row there before the pull request merges. An accepted risk that is written down is a defensible engineering decision; an unwritten one is an oversight.

---

14. Deployment and resource viewpoint

14.1 Topology

Element	Where	Note
API	local Docker on a declared machine – [[ADR-0015-hosting-and-deployment]]	multi-stage image, pinned base, non-root user
Database	S0-S3 a **local PostgreSQL container**; S4 onward Supabase Free tier, Frankfurt – [[ADR-0026-environment-bring-up]]	same engine, same migrations, different connection string
Client	user devices	React Native, built by the second team member after the backend slices land
CI	GitHub Actions, separate `dev` and `prod` configurations, plus an independent client job	builds and tests; **does not deploy**
Merging	`main` requires the `gate` check and `enforce_admins`; **not** that a branch be up to date, since merge queue is unavailable on this plan – [[ADR-0040-pull-requests-need-not-be-up-to-date]]. Auto-merge lands a pull request when `gate` is green	`backend-prod` runs on every push to `main`, so a semantic conflict two green pull requests create together is red within minutes

Element	Where	Note
Observability	Serilog to stdout; OpenTelemetry exporter configuration-driven, **off by default** – [[ADR-0022-observability-stack]]	switched on for a load run
Secrets	`EnvSecretProvider` for the everyday loop; `InfisicalSecretProvider` behind the same abstraction, vault self-hosted in the compose stack under a `vault` profile – [[ADR-0029-containerised-dev-and-secret-vault]]	**required scope.** The abstraction lands early, the vault at S1b, and the delivered system runs on it

The defence runs on the local stack. No remote deployment target is chosen yet; Vercel cannot host this API (serverless, no long-lived process, no persistent WebSocket).

The database being off-premise must be stated in the load report: network latency to Supabase is part of the measured numbers, not an excuse for them.

14.2 Reproducibility

Subject R1 IV.1 requires dependencies to install automatically from a fresh clone. The path:

```
clone  ->  cp .env.example .env  ->  fill values  ->  make up
```

`Makefile` and `docker-compose.yml` exist, and the path above is verified end to end: the API container serves `/health` and `/health/ready` against the compose PostgreSQL. Built in slice S0 of [[delivery-plan]]; rules in [[ci-cd-containerization]]. Issue O10 is closed. CI builds and tests but does not deploy – [[ADR-0015-hosting-and-deployment]].

14.3 Configuration

Development is **fully containerised**: `docker compose up` brings up the stack and the host needs Docker and nothing else – [[ADR-0029-containerised-dev-and-secret-vault]]. No documented step requires a locally installed SDK, database client or CLI; `dotnet-ef` is pinned through `.config/dotnet-tools.json`.

Secrets are read through a provider abstraction, so the vault replaces the environment without touching a call site. The vault is **required scope** – [[ADR-0029-containerised-dev-and-secret-vault]], amended 2026-09-27 – and it lands at S1b. It **shrinks** `.env` to the vault's own bootstrap credentials; it does not remove it, and subject V.8 still applies to what remains.

All configuration from environment variables, named after the role rather than the vendor (`DATABASE_URL`, not a provider name) – [[ADR-0026-environment-bring-up]]. External credentials are created just in time: mail before S1, YouTube and the Supabase project before S4, Google and Facebook before S8. Every key is listed in `.env.example` with a placeholder. `.env` is git-ignored. R1 V.8 makes a publicly stored credential an automatic project failure.

14.4 Capacity

Tool: **Gatling**, simulations committed under `tests/load/` – [[ADR-0018-load-testing-tool]]. It is named in the subject and supports WebSocket natively, so one methodology covers both REST throughput and SignalR fan-out. It runs as `gatling-maven-plugin` inside `maven:3-eclipse-temurin-21` and not from a Gatling image, because no official Gatling image resolves; SPEC-023 records the deviation with its probe evidence.

Measured on 2026-10-03 — `docs/load/REPORT.md`. Five scenarios, five steps each from 10 to 200 concurrent, against one API container and one PostgreSQL container on an Apple M5 Pro whose Docker VM had 15 CPUs and 7.75 GiB. The stated figure is **100 concurrent users performing contended writes, and 200 reading or listening, on that machine**. REST throughput and SignalR connection fan-out are measured separately — they are different limits. See [[load-testing]].

The bottleneck is **PostgreSQL's connection count, not CPU**: at 200 concurrent collaborators a quarter of the reads answered `500` with `53300: sorry, too many clients already` while 62% of the VM's CPU was still idle. Npgsql's default maximum pool size equals the server's default `max_connections`, so the pool may ask for more connections than the server will give. The pair of numbers that fixes it is a deployment decision and is issue O22.

The measurement also found a defect in shipped code: the rate limiter ran before authentication, so SPEC-018's per-account vote policy partitioned on the remote address and a whole venue shared one allowance. [[ADR-0041-limiter-after-authentication]] fixes the order, §13.3 records it, and the re-measurement is in the report.

The figure above is for this machine and this topology only. The API is on-premise and the database is off-premise once S4 lands: latency to Frankfurt will be inside every number measured then, and Supabase's pooler changes the connection ceiling entirely, so that run is a new measurement rather than a correction of this one.

---

15. Design rationale

Rationale is not restated here. Each decision has its own record with the alternatives that were rejected and why — evaluators ask "why not X", and the answer must be on file.

ADR	Decision	Status
[[ADR-0001-backend-dotnet-narchitecture]]	.NET 10, Clean Architecture + CQRS	Accepted
[[ADR-0002-mobile-react-native]]	React Native client, deferred	Accepted
[[ADR-0003-music-provider-youtube]]	YouTube as the music provider	Accepted
[[ADR-0004-realtime-signalr]]	SignalR over WebSocket	Accepted
[[ADR-0005-api-style-rest-json]]	REST + JSON + OpenAPI	Accepted
[[ADR-0006-datastore]]	Supabase managed PostgreSQL	Accepted
[[ADR-0007-password-hashing-bcrypt]]	BCrypt for password hashing	Accepted
[[ADR-0008-oidc-social-login]]	OpenID Connect for Google and Facebook	Accepted
[[ADR-0009-code-quality-gates]]	OWASP conformance and enforced code-size limits	Accepted
[[ADR-0010-service-scope]]	Ship all three services	Accepted
[[ADR-0011-solution-layout]]	Layout mirrors nArchitecture	Accepted
[[ADR-0012-test-stack]]	xUnit, NSubstitute, Testcontainers	Accepted
[[ADR-0013-mail-provider]]	Hosted transactional mail provider	Accepted
[[ADR-0014-location-time-licence]]	Geofence plus optional event code	Accepted
[[ADR-0015-hosting-and-deployment]]	Local Docker, CI without deployment	Accepted
[[ADR-0016-supabase-plan-region]]	Supabase Free tier, Frankfurt	Accepted

ADR	Decision	Status
[[ADR-0017-playback-session]]	PlaybackSession aggregate, client-driven advance	Accepted
[[ADR-0018-load-testing-tool]]	Gatling for load testing	Accepted
[[ADR-0019-hub-action-auditing]]	Audit hub actions with the same record	Accepted
[[ADR-0020-monorepo-layout]]	Backend and client in one repository	Accepted
[[ADR-0021-backend-dependency-set]]	MediatR, FluentValidation, built-in rate limiting and OpenAPI	Accepted
[[ADR-0022-observability-stack]]	Serilog with OpenTelemetry	Accepted
[[ADR-0023-catalog-cache]]	Two-level catalog cache	Accepted
[[ADR-0024-expiry-and-cleanup]]	Lazy expiry checks, one cleanup service	Accepted
[[ADR-0025-agent-git-protocol]]	Git protocol for unattended agent runs	Accepted
[[ADR-0026-environment-bring-up]]	Environment bring-up sequence	Accepted
[[ADR-0027-agent-push-and-pr]]	Agents push a branch and open a draft pull request	Accepted
[[ADR-0028-domain-owns-its-base-types]]	Domain owns its base types; Application owns its abstractions	Accepted
[[ADR-0029-containerised-dev-and-secret-vault]]	Containerised development, self-hosted secret vault	Accepted
[[ADR-0036-access-token-mechanics]]	JwtBearer, a `sid` claim, 30 seconds of clock skew	Accepted
[[ADR-0037-credential-rate-limiting]]	Per-IP middleware plus a per-account in-process counter	Accepted
[[ADR-0032-refresh-token-lifetime]]	30-day absolute refresh-token families	Accepted
[[ADR-0033-audit-write-posture]]	The audit record commits with its action, and fails closed	Accepted
[[ADR-0034-profile-storage-and-visibility]]	Typed profile columns with a tier each	Accepted
[[ADR-0038-realtime-broadcast-posture]]	A handler queues a broadcast; a behaviour sends it after the commit	Accepted
[[ADR-0039-queue-broadcast-payloads]]	An `EventHub` payload carries the authoritative value, not a row version	Accepted

An accepted ADR is never edited. It is superseded by a new one.

---

16. Requirements traceability

Every mandatory requirement of R1, mapped to the design element that satisfies it. This is the table to walk through at defence.

Subject	Requirement	Design element	Status
V.1	email+password or social registration	§10.1, §10.2, §13.1	**partly implemented** – `POST /api/v1/auth/registrations` persists an unverified `User` with a BCrypt hash at work factor >= 12, `ux_users_email` arbitrates the race, and both a fresh and an already-registered address answer `202` so the endpoint is not an enumeration oracle. Social registration is designed only. A verified account can now sign in, and **the API can tell who is calling**: `AddJwtBearer` validates the signature, issuer, audience and lifetime of the token this service signed, and `DELETE /auth/sessions/current`, `GET /auth/sessions` and `DELETE /auth/sessions/{sessionId}` work — logout revokes the refresh-token family named by `sid`, so a kept copy of the refresh token is worthless afterwards. `POST /api/v1/auth/sessions` verifies the stored hash and answers a 15-minute JWT plus an opaque refresh token, and every failure – unknown address, wrong password, unverified account – answers the same bodiless `401` for the same amount of hashing work. Rate limiting is **in place** on this endpoint and on every other credential endpoint — per-IP policy plus a per-account counter, §13.3 — so T-25 is closed

Subject	Requirement	Design element	Status
V.1	link a social account	§10.2, Identity context	designed

Subject	Requirement	Design element	Status
V.1	email verification + forgot password	§10.1, §13.1	**partly implemented** – verification works end to end: registration issues a 256-bit token, stores only its SHA-256 hash and hands the plaintext to `IMailService`; `POST /api/v1/auth/email-verifications` spends it exactly once through a `consumed_at_utc IS NULL AND expires_at_utc > @now` conditional update and sets `is_email_verified`. `204` verified, `410` expired, `400` for unknown, malformed and already-consumed alike, so the endpoint is not an enumeration oracle. A parallel test proves 20 concurrent verifications of one token produce exactly one `204`. Resending works too: `POST /api/v1/auth/verification-requests` issues a fresh token for an existing unverified account and supersedes that account's outstanding tokens in the same transaction, so exactly one link is live at a time; an unknown address, an already-verified account and a failed send are all answered `202` and send nothing, so the endpoint is not an enumeration oracle. **Mail now leaves the machine** (SPEC-024): `MAIL_PROVIDER=brevo` registers `BrevoMailService`, which posts the verification and reset messages to the hosted provider of ADR-0013 over a typed client with a 10-second timeout and no retry, logging the recipient and the provider's message id and never the token or

Subject	Requirement	Design element	Status
V.1	three profile visibility tiers	§6.2, §13.2, §8	**partly implemented** – every tiered field carries `Public`, `Friends` or `Private` in its own column, set in the same call as the value it governs: `GET /api/v1/me` returns each field with its tier, `PATCH /api/v1/me/profile` updates any subset and answers `422` for a value sent without a tier, and `PUT /api/v1/me/music-preferences` replaces the preference set (subject V.1's other half, storage-only — issue O14). A profile row is created with the account, and the accounts that predate the table were backfilled by an idempotent data migration. **The projection is built** (SPEC-013): `GET /api/v1/users/{userId}` returns each field only when the reader's relationship clears its tier, decided in the SQL projection so a hidden value never enters the process, and `GET /api/v1/users` searches display names only. All three tiers now give three different answers, and a friendship being removed hides the fields again on the next read. **The friends graph is built** (SPEC-012): requests in both directions, acceptance arbitrated by a conditional `UPDATE` with the friendship insert in the same transaction, decline, withdrawal, removal and both listings — so `Friends` is now a tier that can be evaluated. A parallel test proves 20 simultaneous accepts of one request create exactly one friendship

Subject	Requirement	Design element	Status
V.2.1	live vote-ordered queue	§5.2, §10.3, §9.2	**implemented** – the queue is ordered by a count read from the vote rows, with ties broken on when a track was suggested so the order is total and stable, and each row reports whether the caller voted. **It is live:** `EventHub` at `/hubs/events` authorises every join server-side through the `member` gate, audits join and leave through ADR-0019's filter, and pushes `TrackSuggested`, `VoteChanged` — carrying the suggestion's new count — and `QueueReordered` **after** the transaction commits, through the same behaviour and queue `PlaylistHub` uses. A refused write and a duplicate vote both broadcast nothing. `NowPlayingChanged` belongs to the playback session of slice S7. Remaining gap, recorded and not silent: one instance, no backplane – O8

Subject	Requirement	Design element	Status
V.2.1	a highly-voted track **plays** earlier	§10.6, §11.2, [[ADR-0017-playback-session]]	**implemented** – a session opened on an event starts on the most-voted suggestion, and each advance plays the next most-voted, ties broken by the earliest suggestion. The **server** picks; the client only reports that a track ended. `expectedNowPlayingId` makes a retry harmless — a stale expectation answers `200` with the current state rather than skipping a second track — while a stale `If-Match` answers `412`. Twenty parallel advances move the session exactly once (SPEC-021)
V.2.1	public/private visibility	§6.2, §13.2	**implemented** – an event is `Public` or `Private`; a private event answers `404` to anybody who is neither its owner nor an invitee, and appears in no list scope. An invitation is the gate and is read live, so withdrawing one takes effect on the invitee's next call (SPEC-017)

Subject	Requirement	Design element	Status
V.2.1	licence modes incl. location+time	§6.2, [[ADR-0014-location-time-licence]]	**implemented** – all three modes are stored, and a `LocationAndTimeRestricted` event cannot exist without a presence policy (`422` at creation and on `PUT .../licence`). The check is enforced on the vote: a great-circle distance against the event's own centre, a venue code verified as a digest and spent once per account, or both, all against **server time**. A failed proof is one `422` with one message. The submitted coordinate is compared and discarded. Residual risk, stated and not hidden: client-reported GPS is spoofable – T-17
V.2.1	vote race conditions	§12.1 #1, §12.2	**implemented** – nothing increments a counter, because no counter exists: twenty accounts voting for one suggestion in parallel produce twenty rows and a count of twenty. Twenty parallel requests from one account produce one row – one `201`, nineteen `200` – arbitrated by `ux_event_votes_event_id_suggestion_` Twenty parallel suggestions of one video produce one suggestion and nineteen `409`s, and twenty parallel votes carrying one venue code spend it exactly once

Subject	Requirement	Design element	Status
V.2.2	per-device control licence, delegation	§5.2, §10.5, §11.3	**implemented** – a device is registered from the mandatory client headers and is unique per owner, platform and model; its owner may hand playback control to a **friend** (`422` for anybody else, checked against the graph SPEC-012 built) through a `PUT` guarded by the row's `xmin`; the owner may revoke and the controller may release, both returning the device to its owner. Ownership is checked before the friendship rule, so a non-owner gets the `404` a stranger gets and learns nothing. Twenty simultaneous claims produce exactly one `200`, nineteen `412` and one controller in the database (SPEC-020) **It is live:** `ControlHub` at `/hubs/control` pushes `ControlGranted` to the grantee and the owner, `ControlRevoked` to both on a revoke or a release, and `ControlTakenOver` to a controller a new grant displaced — the displaced account read inside the guarded transaction, so it cannot be a guess a concurrent grant invalidated (SPEC-022)

Subject	Requirement	Design element	Status
V.2.2	what a delegate actually controls	the device's grant, read by the session – [[ADR-0017-playback-session]]	**implemented** – a delegate advances and jumps a live session, and the owner cannot while the grant stands: the gate is exclusive, and the owner's recourse is to revoke. The session stores no controller of its own, so the grant has exactly one home (SPEC-020) and a revoke takes effect on the delegate's next command. Starting and stopping stay the owner's: a delegate steers what plays and does not switch the speaker off

Subject	Requirement	Design element	Status
V.2.3	realtime multi-user playlist editing	§9.2, §10.4	**implemented** – the playlist aggregate exists with its three gates (`member`, `owner`, `licence`), a concurrency token that is PostgreSQL's own `xmin`, an `ETag` derived from it and an `If-Match` compared inside the `UPDATE` so a stale writer changes nothing and is told `412`. Collaborators carry `can_edit`, which separates reading from writing. Soft delete hides a playlist from every read. Tracks carry a `bigint` sparse `position` with a gap of 1000, insert after a named neighbour or at the head or tail, renumber when a gap runs out, cap at 500 tracks with a `409`, and allow the same video twice. **It is live:** `PlaylistHub` at `/hubs/playlists` authorises every join server-side through the same `member` gate, audits join and leave through ADR-0019's filter, and pushes `TrackAdded`, `TrackMoved`, `TrackRemoved` and `CollaboratorChanged` — each carrying the playlist's new version — **after** the transaction commits, by a behaviour registered outside it (ADR-0035). A refused write broadcasts nothing. Remaining gap, recorded and not silent: one instance, no backplane – O8

Subject	Requirement	Design element	Status
V.2.3	reorder race conditions	§12.1 #2, §12.2	**implemented** – every track write updates the playlist row inside its own transaction, keyed on the `xmin` the caller read, so that one statement is both the precondition and the lock. Twenty parallel moves of one track with one token produce exactly one `200`, nineteen `412`, and a final order that is still a permutation of the original with distinct positions; twenty parallel adds with one token add one track. Every refusal is decided before the parent is touched, so a refused write leaves the caller's `ETag` valid
V.2	at least 2 of the 3 services	§5.2, [[ADR-0010-service-scope]]	**implemented** – all three ship. Playlist Editor at S5, Track Vote at S6, Control Delegation with Playback at S7; each one's own rows above carry the evidence
V.3	backend is the single source of truth	§4.2, §8.1	designed

Subject	Requirement	Design element	Status
V.4	REST, JSON, reference documentation	§9.1, [[endpoint-inventory]], [[ADR-0021-backend-dependency-set]]	**partly implemented** – `docs/api/openapi.json` is generated from the code, committed, and guarded against drift by `make agent-check`: it documents every route that exists, across identity, profiles and the social graph, playlists and their tracks, events with their licence policy, roster, queue, votes and venue codes, devices and control delegation, playback sessions, the audit read and the two health probes. Each mutating route documents the `400` its mandatory client headers can produce and each authenticated route its `401`. **The generated document is the count; this row deliberately does not repeat it, because a number written here rots.** The three hubs are not in it — OpenAPI describes HTTP, and the realtime contract lives in §9.2
V.5	client is a remote control	§4.1, §9.1	designed
V.5	configurable backend address	§9.1, [[musicroom-mobile]]	designed
V.5	social authentication on mobile	§10.2	designed

Subject	Requirement	Design element	Status
V.6	own data only, never another user's	§13.2 (see its table of where each gate lives)	**partly implemented** – **the per-field visibility gate is enforced server-side** (SPEC-013): a reader receives only the fields their relationship clears, the projection happens in the query rather than in memory, and search cannot be used to probe a hidden value. The first `self` gate also exists: `GET /api/v1/auth/sessions` lists only the calling account's sessions, and `DELETE /api/v1/auth/sessions/{sessionId}` answers `404` for an id that is unknown, already ended **or another account's**, because a distinct answer would confirm it exists. The account comes from the validated token and never from the request. The ownership pipeline behaviour §13.2 describes arrives with the aggregates that need it, S3 onward

Subject	Requirement	Design element	Status
V.6	brute force and session theft protections	§13.1, §13.3	**implemented** – **brute force:** every credential endpoint carries a per-IP policy (one per endpoint, so a registration loop cannot spend the sign-in allowance) and a per-account counter with progressive backoff, answering `429` with `Retry-After` and an empty body; the numbers are in §13.3 and the trip is logged without naming the account. **Session theft:** refresh tokens are stored only as SHA-256 digests, rotate on every use through a `consumed_at_utc IS NULL AND revoked_at_utc IS NULL AND expires_at_utc > @now` conditional update, and presenting an already-rotated token revokes the whole family in the same transaction. Parallel tests prove both concurrency claims: 20 concurrent rotations of one token produce exactly one `200`, one spent row and one replacement. Remaining gap, recorded and not silent: limiter state is per process, so several instances would each hold their own – O8 **Realtime, SPEC-026:** the hub transport now carries ADR-0030's three controls — a 5-per-account and 20-per-address concurrent connection ceiling refused at the handshake and again at connect, 60 invocations a minute per connection throwing a `HubException` that is audited `refused`, and an `Origin` check against `CORS_ALLOWED_ORIGINS` that answers 403

Subject	Requirement	Design element	Status
V.6	document remaining threats	§13.6, [[threat-register]]	**partly implemented** – the register's table carries 29 rows and its Accepted section carries one more residual risk, T-30, so the highest id is ahead of the row count by design. The Verified column is filled for every threat a shipped slice closed or bounded: T-01, T-06, T-11, T-12, T-17, T-19, T-25, T-26, T-27, T-28 and T-29 all name tests or code paths, and T-30 is accepted with its reasoning rather than verified. The rows still empty belong to slices that do not exist yet. Issue **O20** – renumbered from O19 when the OpenID Provider work claimed that id – is the one item §13.2 claimed and did not have. **Update 2026-10-04, SPEC-027:** the register carries 32 rows plus T-30's accepted residual, and `docs/owasp/ASVS-CONFORMANCE.md` now states an outcome for each of the 142 committed ASVS requirements with a named artifact or a reason — 66 met, 5 partial, 47 not met (29 of them V10, waiting on S8, and 3 TLS, waiting on a deployment) and 24 not applicable. The pass itself opened T-31 to T-33: no authenticated change-password endpoint, no breached-password or context-word screening, and logs that are neither protected nor shipped. **T-31 closed the same day**, by SPEC-028's `PUT /me/password`, which is why the counts above already say 66 and 47: V6.2.2, V6.2.3 and V7.5.1 moved to met and V7.4.3 gained its

Subject	Requirement	Design element	Status
V.6	log platform, device, app version per action	§10.7, §13.4, [[ADR-0019-hub-action-auditing]]	**partly implemented** – **REST is done:** middleware refuses any mutating request that omits `X-Client-Platform`, `X-Client-Device` or `X-Client-App-Version` with a bodiless `400`, and an `AuditBehaviour` writes exactly one `audit_records` row per handled command, carrying those three values plus the action, the target type, the trace id and the instant. The record is written **inside the command's transaction**, so an effect without a record cannot exist and a record without an effect cannot either; if the audit write fails the whole command fails (owner decision, 2026-09-27, fail closed). A command refused by validation leaves no record. `user_id` is null on every row until an endpoint authenticates its caller, because every mutating endpoint that exists is anonymous – stated, not hidden, and it is now populated wherever the handler knows the account. Since SPEC-009 the row also says **what became of** the action — `completed`, `refused`, `throttled`, `expired` or `reusedetected` (§13.4) — so a failed login, a rejected token and a detected refresh-token family revocation are each visible as themselves. A throttled credential attempt is recorded too, which needed the limiter's refusal to stop being an exception. **The hub is covered too** (SPEC-016):

Subject	Requirement	Design element	Status
V.7	measure and justify concurrent users	§14.4, `docs/load/REPORT.md`, `tests/load/`	**done** — five Gatling scenarios, 10 to 200 concurrent; 100 concurrent writers and 200 readers on the declared machine, with the bottleneck named (PostgreSQL connections, not CPU) and O22 opened for it
V.7	declare server specification	§14.4, `docs/load/REPORT.md` §1	**done** — host and Docker VM both declared, because only one of them is the system under test. The hosted figure is a separate measurement once O11 and S4 land
V.6	OWASP conformance of all code	[[asvs-conformance]], §13	target committed, evidence pending

Subject	Requirement	Design element	Status
V.8	per-layer tests	[[testing]], [[ADR-0012-test-stack]]	**partly implemented** – tests in four projects, the count being whatever `make agent-check` prints rather than a number that rots here: validation and pipeline behaviours (`MusicRoom.Application.Tests`), infrastructure (`MusicRoom.Infrastructure.Tests`), persistence (`MusicRoom.Persistence.Tests`, which holds the built model to the schema naming conventions without needing an engine) and API integration (`MusicRoom.WebAPI.Tests`, Testcontainers-backed against a real PostgreSQL). Every slice with a contended write carries the parallel test AGENTS.md requires, each asserting final database state rather than status codes alone: one row from 20 parallel registrations of an address; one `204` and one `consumed_at_utc` from 20 verifications of a token; one `200`, one spent row and one replacement from 20 refresh-token rotations; one `204` and no live refresh token from 20 password resets; one friendship from 20 accepts; one `200` and nineteen `412` from 20 playlist reorders; twenty votes and a count of twenty from twenty accounts, against one row from 20 votes by one account; one spent venue code; one controller from 20 simultaneous claims; and one track advanced from 20 parallel advances. **The realtime layer is tested too** – three hub suites and three broadcast suites drive a

Subject	Requirement	Design element	Status
V.8	continuous integration	[[ci-cd-containerization]]	**done** – `.github/workflows/backend-dev.yml` and `backend-prod.yml`: restore, format, build -warnaserror, test, vulnerable-package scan, OpenAPI drift check; prod also builds the image. No deployment, by [[ADR-0015-hosting-and-deployment]]
V.8	credentials in a git-ignored `.env`	§14.3, `.env.example`	**done**
V.8	enforced code quality	[[dotnet-csharp]], `.editorconfig`, `MusicRoom/SonarLint.xml`	**done** – proven live in S0: a 47-line method fails the build with `S138 ... greater than the 40 lines authorized`, and six parameters fail with `S107`. The thresholds moved to `SonarLint.xml`; in `.editorconfig` they were silently ignored
IV.1	no third-party source in the repo	§5.1, `.gitignore` excludes `reference/`	**done**
IV.1	dependencies install from a fresh clone	§14.2, `Makefile`, `docker-compose.yml`	**done** – clone, `cp .env.example .env`, fill, `make up`. Verified end to end: the API container serves `/health` and `/health/ready` against the compose PostgreSQL
IV.2	mobile app covers all operations	`MusicRoomApp/`, [[musicroom-mobile]]	sequential workstream, owned by the UI developer; starts after S9 — [[delivery-plan]] "Work split"
VII	submitted in the git repository	[[ADR-0020-monorepo-layout]]	**designed** – one clone holds backend, client and documentation

Subject	Requirement	Design element	Status
III	the SDK must not do our work	§9.3, `tests/.../Catalog`	**implemented** — `GET /api/v1/tracks` and `GET /api/v1/tracks/{youtubeVideoId}`, both authenticated, behind one adapter and ADR-0023's two cache levels. YouTube supplies metadata only: voting, licences, visibility, delegation and collaborative editing are this system's own logic and none of them calls the provider. A write path never does either, so a provider outage costs titles rather than an event. The key is server-side, the quota cost of every call is logged, and no test spends it

"Designed" means the decision and the mechanism are recorded, and nothing more. "Partly implemented" and "done" name code that exists on a branch and passes `make agent-check`; the row says which part, because a requirement is rarely finished in one slice.

---

17. Open design issues

Closed rows stay visible: a decision log that hides what it used to not know is less useful at defence, not more.

Open

#	Issue	Blocks	Note
O8	SignalR scale-out backplane (Redis)	multi-instance deployment	**deliberately open.** Not needed for a single-instance defence
O11	remote deployment target	a live demo URL	[[ADR-0015-hosting-and-deployment]]. Fly.io, Railway, Render, Azure Container Apps. **Not Vercel**
O12	fluent assertion library	test readability	add only if xUnit's built-ins prove insufficient

#	Issue	Blocks	Note
O13	silent-controller recovery	a stalled playback session	[[ADR-0017-playback-session]] accepted no watchdog; takeover is the manual path. Revisit only if it bites in testing
O18	self-hosted Infisical vault	API keys sitting readable in `.env`	[[ADR-0029-containerised-dev-and-secret-vault]], amended 2026-09-27: **required scope, not optional.** The provider abstraction lands early, the vault at S1b, after the mail adapter at S1a (O17). Self-hosted Infisical needs its own PostgreSQL, Redis and encryption key — roughly five compose services instead of two. Subject V.8 does not ask for it; the owner does, and the delivered system runs on it. It is planned alongside S1 to S9, not after them
O14	music preferences have no consumer	nothing	V.1 requires storing and updating them, which is met. Note for defence: storage-only today
O19	RS256 key pair: generation, storage, JWKS exposure and rotation with an overlap window	the OpenID Provider surface at S8	[[ADR-0031-musicroom-as-openid-provider]]. `EnvSecretProvider` holds the private key until the vault lands at S1b, after which it belongs there. Rotation needs an overlap so tokens signed by the outgoing key keep verifying

#	Issue	Blocks	Note
O20	PostgreSQL Row Level Security policies are not written	nothing — it is defence in depth	§13.2 claimed RLS was enabled; no migration creates a policy. Opened by the SPEC-013 SDD sync on 2026-09-29. Deny-by-default policies on the per-account tables would mean a query that forgot its `WHERE` returns nothing rather than everything. Cost: every read path needs a session variable carrying the caller, which the current single-connection-pool design does not set
O22	Npgsql pool size and PostgreSQL `max_connections` are not set against each other	the V.7 figure above 100 concurrent writers	opened by SPEC-023's measurement on 2026-10-03. Both default to 100 and the server reserves superuser slots, so the pool may ask for connections the server will not give and the request fails with `53300` instead of queueing. Capping the pool below `max_connections` fixes the failure mode; raising `max_connections` moves the ceiling. **Not fixed here on purpose:** S4 moves `DATABASE_URL` to Supabase, whose pooler changes the arithmetic, and [[load-testing]] requires the change and its re-measurement in one unit

#	Issue	Blocks	Note
O23	No backup of the development database	nothing graded — owner requirement, 2026-10-04	`pg_dump` of the compose Postgres into a directory, with a retention count and a restore path. Needs an ADR before a spec, because the spec gate trips twice: question 1 (no accepted decision covers it) and question 5 (`pg_dump` reads the `.env` credential, and a dump carries real user rows — hashes and addresses). Three things the ADR has to settle: where the directory lives and that it is git-ignored **in the same commit** (V.8 makes a committed credential an automatic failure); that the dump runs as `docker compose exec db pg_dump` rather than a host binary, since `psql` is absent from the toolchain [[MEMORY]] records and [[ADR-0026-environment-bring-up]] keeps the host empty; and how a restore is proved, because a backup nobody restored is a file
O16	OpenTelemetry must earn its place	credibility of the V.7 bottleneck claim	[[ADR-0022-observability-stack]]: capture one trace during the Gatling run showing EF Core, HttpClient and total request time together

Closed

#	Issue	Closed by
O21	hub call limits and handshake origin decided and not built	**SPEC-026, 2026-10-04.** The ceiling, the per-connection invocation limit and the `Origin` check all exist, with the numbers the owner set in [[ADR-0030-hub-rate-limits-and-origin]] on the same day. `CORS_ALLOWED_ORIGINS` is read by code for the first time, which is the half of this issue the brain-check of 2026-10-02 found. T-12 narrows from "bounded payloads and timeouts" to a stated limit with tests behind it; the per-process residual is O8, unchanged
O17	real mail provider adapter	**SPEC-024, 2026-10-04.** `BrevoMailService` behind `IMailService`, selected by `MAIL_PROVIDER`; the Development logging sender stays for local work and is refused anywhere else. Verification and reset messages now reach a real mailbox, from Brevo's sandbox sender (§10.1). Closes T-26 with it
O1	which services ship	[[ADR-0010-service-scope]] — all three
O9	concrete table and column definitions	the migrations, not a document: `InitialIdentity`, `RefreshTokens`, `PasswordResetTokens` and `AuditRecords` ([[migrations-index]]). `SchemaConventionTests` holds the built model to the naming rules
O15	MediatR licence terms	[[ADR-0021-backend-dependency-set]] records the verification of 2026-09-24: the free Community License covers this project, so MediatR stays and the hand-written dispatcher is not needed
O10	`Makefile` and `docker compose`	slice S0 — both exist, `make up` verified end to end against the compose PostgreSQL
O2	solution and folder layout	[[ADR-0011-solution-layout]]
O3	test framework	[[ADR-0012-test-stack]]
O4	API hosting target	[[ADR-0015-hosting-and-deployment]]
O5	Supabase plan tier and region	[[ADR-0016-supabase-plan-region]]

#	Issue	Closed by
O6	SMTP provider	[[ADR-0013-mail-provider]]
O7	location+time licence enforcement	[[ADR-0014-location-time-licence]]
G1	queue advance / playback progression	[[ADR-0017-playback-session]]
G2	what a control delegate actually controls	[[ADR-0017-playback-session]]
G3	load testing tool	[[ADR-0018-load-testing-tool]]
G4	hub actions missing from the audit log	[[ADR-0019-hub-action-auditing]]

Related

[[HOME]] · [[MEMORY]] · [[system-overview]] · [[domain-model]] · [[realtime-architecture]] · [[auth-and-identity]] · [[decisions-index]] · [[subject-requirements]] · [[technical-guide-index]] · [[user-manual]]